Incident Technique – Échec d’authentification des comptes Protected Users

Projet : Bastion sécurisé

Criticité : 🔴 Élevée — Impact sur les accès administrateurs Tier 0

Environnement : Apache Guacamole 1.6.0 · FreeRDP · Active Directory (modèle de Tiering)

1. Contexte technique

Dans le cadre du déploiement d'un **bastion de rebond sécurisé** reposant sur Apache Guacamole (`guacd` + FreeRDP), des tests d'accès aux serveurs critiques (Tier 0) ont mis en évidence une anomalie d'authentification affectant exclusivement les comptes membres du groupe Active Directory **Protected Users**.

L'environnement opère dans un contexte de durcissement strict, conforme aux recommandations Microsoft pour le modèle de Tiering Active Directory. Cette politique interdit explicitement l'usage de protocoles d'authentification hérités, notamment NTLM.

La capture ci-dessous illustre les erreurs remontées par `guacd` lors des tentatives de connexion échouées :

```
[redacted]: INFO:        RDP server closed/refused connection: Access denied by server (account locked/disabled?)
[redacted]0d-7a54-45b7-a8c2-499cb7f43a09" disconnected (0 users remain)
[redacted]: INFO:        User "@2a2a330d-7a54-45b7-a8c2-499cb7f43a09" disconnected (0 users remain)
[redacted]connection "$9925c2e1-4620-4421-85f8-f8daa22b27d4" disconnected
[redacted]: INFO:        Last user of connection "$9925c2e1-4620-4421-85f8-f8daa22b27d4" disconnected
[redacted]9925c2e1-4620-4421-85f8-f8daa22b27d4" removed.
[redacted]: INFO:        Connection "$9925c2e1-4620-4421-85f8-f8daa22b27d4" removed.
```

2. Description de l’incident

Symptôme principal

Les comptes membres du groupe **Protected Users** ne peuvent pas établir de session RDP via le bastion Guacamole, alors que les comptes standards s’authentifient normalement.

Comportement observé

- Les comptes standards fonctionnent sans anomalie.
- Les comptes **Protected Users** échouent de manière systématique et immédiate.
- Guacamole renvoie une erreur générique de négociation RDP, sans message explicite lié à Kerberos.
- Aucun prompt d'authentification Kerberos n'est présenté à l'utilisateur.

Impact

- **Blocage total** des accès administratifs aux serveurs Tier 0.
- **Non-conformité** avec la politique de sécurité Active Directory en vigueur.

3. Analyse des causes — Root Cause Analysis

3.1 Comportement du groupe Protected Users

Le groupe **Protected Users** est un groupe de sécurité Active Directory conçu pour protéger les comptes à privilèges élevés contre les attaques basées sur le vol de credentials. Il impose les restrictions suivantes de manière non négociable :

- Interdiction stricte de l'authentification NTLM (toutes versions)
- Interdiction du stockage de credentials en cache
- Obligation d'authentification Kerberos exclusivement
- Refus de tout mécanisme d'authentification legacy

Rappel technique — Pourquoi NTLM est proscrit en Tier 0

NTLM (NT LAN Manager) est un protocole d'authentification historique basé sur un mécanisme challenge-réponse. Il est intrinsèquement vulnérable à plusieurs classes d'attaques courantes en environnement Active Directory : le **NTLM Relay** (interception et réutilisation des échanges d'authentification), le **Pass-the-Hash** (utilisation directe du hash NTLM sans connaissance du mot de passe) et le **Credential Replay** (rejeu de jetons capturés). Dans un périmètre Tier 0, son usage est donc formellement proscrit. Toute tentative NTLM de la part de Guacamole est rejetée immédiatement par l'Active Directory.

3.2 Cause n°1 — Version FreeRDP inadaptée

La version FreeRDP 2.x, disponible dans les dépôts officiels Ubuntu 22.04, présente plusieurs limitations critiques dans un contexte Active Directory durci. Elle supporte Kerberos de manière partielle et non conforme, ne force pas correctement GSSAPI lors de la négociation, et ne gère pas les scénarios NLA (Network Level Authentication) stricts. La conséquence directe est un **fallback implicite vers NTLM** lorsque la négociation Kerberos échoue, ce qui déclenche un rejet systématique par l'AD pour les comptes Protected Users.

3.3 Cause n°2 — Liaison dynamique incorrecte

Le module RDP de Guacamole (`libguac-client-rdp.so`) n'était pas lié dynamiquement à la bibliothèque Kerberos système (`libgssapi_krb5`). Sans cette liaison, `guacd` était structurellement incapable d'accéder aux tickets Kerberos (TGT) présents dans le cache système, même si ceux-ci étaient valides.

La vérification initiale ayant confirmé l'anomalie :

```
ldd /usr/local/lib/libguac-client-rdp.so | grep gss
```

L'absence de toute sortie confirme qu'aucune liaison GSSAPI n'existe. Le module RDP est complètement aveugle au moteur Kerberos du système.

4. Solution mise en œuvre

La résolution a nécessité une **reconstruction complète de la chaîne RDP**, depuis FreeRDP jusqu'à Guacamole Server.

Étape A — Migration vers FreeRDP 3.2.0

La version FreeRDP 2.x a été remplacée par une compilation manuelle de FreeRDP 3.2.0, avec activation explicite des modules Kerberos :

1. Désinstallation de la version FreeRDP 2.x issue des dépôts
2. Compilation manuelle de FreeRDP 3.2.0 depuis les sources
3. Activation explicite des options critiques lors du build :

```
-DWITH_GSSAPI=ON
-DWITH_KDCRAW=ON
```

Ces flags garantissent l'activation complète du support Kerberos moderne via GSSAPI, la suppression des mécanismes de fallback NTLM, et la compatibilité

avec les politiques NLA strictes.

Étape B — Recompilation de Guacamole Server 1.6.0

Guacamole Server a été recompilé en ciblant les nouvelles bibliothèques FreeRDP 3, afin que `libguac-client-rdp.so` soit correctement lié à `libgssapi_krb5`.

Vérification post-compilation :

```
ldd /usr/local/lib/libguac-client-rdp.so | grep gss
```

Résultat obtenu :

```
libgssapi_krb5.so.2 => /usr/lib/x86_64-linux-gnu/libgssapi_
krb5.so.2
```

Cette sortie confirme la liaison dynamique GSSAPI valide, l'accès opérationnel au moteur Kerberos du système, et le support GSSAPI pleinement fonctionnel.

Étape C — Automatisation du renouvellement Kerberos via Keytab

Les tickets Kerberos (TGT) ont une durée de vie limitée et expirent par défaut, ce qui aurait entraîné des interruptions de service périodiques. Pour y remédier, un fichier Keytab dédié au compte de service du bastion a été généré, éliminant toute dépendance à une saisie manuelle de mot de passe.

Script déployé :

```
/usr/local/bin/renew_guac_kerberos.sh
```

Commande de renouvellement utilisée :

```
kinit -kt /etc/guacamole/guac.keytab compte-service@DOMAIN
E.LOCAL
```

Le script est planifié via cron avec une fréquence de **8 heures**, garantissant un TGT valide en permanence, sans interruption de service et sans stocker de mot de passe en clair.

5. Prérequis de configuration Guacamole

Pour un fonctionnement Kerberos correct, les paramètres suivants doivent être respectés dans la configuration des connexions Guacamole :

Hostname : Le FQDN complet du serveur cible est obligatoire (ex. : `srv-dc01.domaine.local`). L'utilisation d'une adresse IP invalide le Service Principal Name (SPN) et rompt l'authentification Kerberos.

Security Mode : NLA uniquement.

Username : Compte nominal du domaine, au format `utilisateur@DOMAINE` ou `DOMAINE\utilisateur`.

> ⚠️ Toute déviation par rapport à ces paramètres peut provoquer un retour silencieux vers NTLM, entraînant un échec d'authentification pour les comptes Protected Users.

6. Maintenance et surveillance

Supervision des journaux

```
sudo journalctl -u guacd -f
```

Points d'attention lors de la supervision : erreurs de type `GSSAPI` (liaison ou ticket invalide), **SPN mismatch** (hostname incorrect ou non résolu), échec de la phase **NLA**, et problèmes de négociation TLS.

Synchronisation temporelle

Kerberos impose une synchronisation stricte des horloges : un décalage supérieur à **5 minutes** entre le bastion et les contrôleurs de domaine entraîne un échec d'authentification silencieux, souvent difficile à diagnostiquer.

Service en charge : **Chrony**

```
chronyc tracking
```

Un décalage excessif génère l'erreur `KRB_AP_ERR_SKEW`, sans message d'erreur explicite côté client.

7. Résultat final

Suite à la migration vers FreeRDP 3.2.0, la recompilation de Guacamole Server avec liaison GSSAPI valide, et la mise en place de l'automatisation Keytab, les

comptes **Protected Users** peuvent désormais s'authentifier avec succès via le bastion, établir des sessions RDP vers les serveurs Tier 0, et opérer en conformité totale avec la politique de sécurité Active Directory — sans aucun recours à NTLM.

8. Leçons apprises

1. **Un bastion Tier 0 doit être traité comme un composant Kerberos natif**, et non comme un simple relais RDP. La chaîne d'authentification entière doit être pensée en conséquence dès la conception.
2. **Les paquets Linux issus des dépôts officiels sont fréquemment insuffisants** pour des environnements Active Directory durcis — la compilation depuis les sources avec les options adéquates est souvent incontournable.
3. **La commande `ldd` est un outil de diagnostic critique** pour valider la liaison dynamique des bibliothèques et détecter toute dépendance manquante.
4. **Kerberos échoue rarement de façon explicite** — les erreurs sont souvent masquées par un fallback silencieux vers un protocole moins sécurisé, ce qui rend le diagnostic initial trompeur.
5. **Le respect strict du FQDN dans la configuration Guacamole est non négociable** — une adresse IP invalide le SPN et rompt complètement l'authentification Kerberos.